

Politique de confidentialité et protection des données personnelles

Plateforme CYNA — Services SOC, EDR et XDR en SaaS

Version 1.0 · Juin 2026

Document aligné sur l'implémentation technique de la plateforme (API cyna-api)

La présente politique décrit comment **CYNA-IT** (ci-après « nous », « CYNA ») collecte, utilise, conserve et protège vos données personnelles lorsque vous utilisez le site web **cyna-front.onrender.com**, l'application mobile **cyna-mobile** et l'API associée **laravel-api-1-zb19.onrender.com**.

Ce document reflète les mesures effectivement implémentées dans le code source de la plateforme (services `AccountDeletionService`, `AuditLogger`, configuration `config/audit.php`).

1. Responsable du traitement

CYNA-IT — Éditeur de la plateforme CYNA (cybersécurité managée pour PME).

- **Contact général** : via le formulaire de contact sur le site ou à l'adresse indiquée sur la page « Contact ».
- **Contact données personnelles / RGPD** : rgpd@cyna-it.fr (adresse à confirmer par l'éditeur).

2. Données personnelles collectées

Catégorie	Données	Origine
Compte utilisateur	Prénom, nom, adresse e-mail, mot de passe (stocké sous forme hashée bcrypt)	Inscription (POST /api/auth/register)
Authentification	Tokens API Sanctum (révocables), tokens de confirmation e-mail, tokens de réinitialisation mot de passe	Connexion, vérification e-mail, mot de passe oublié

Commandes et facturation	Nom de facturation, adresse de facturation et livraison, montants, statut commande, 4 derniers chiffres de carte	Processus de commande / abonnement
Paieement	Identifiants Stripe (customer_id, subscription_id) — aucun numéro de carte complet n'est stocké par CYNA	Stripe (prestataire certifié PCI-DSS)
Carnet d'adresses	Adresses postales enregistrées par l'utilisateur	Espace compte
Contact support	E-mail, sujet, contenu du message	Formulaire de contact
Chatbot d'assistance	Messages saisis, réponses générées, identifiant de session	Assistant en ligne (règles locales, sans IA externe)
Journal de sécurité	Adresse IP masquée (dernier octet à zéro), type d'action, horodatage	Actions API et parcours commerce (pages whitelistées)
Connexion administrateur	Code OTP à usage unique (hashé en base, non stocké en clair)	Backoffice admin

3. Finalités et bases légales

Finalité	Base légale (RGPD)	Implémentation
Création et gestion du compte	Exécution du contrat (art. 6.1.b)	Inscription, profil, authentification Sanctum
Vérification de l'adresse e-mail	Exécution du contrat / intérêt légitime	Token de confirmation (expiration : 24 h par défaut)
Souscription et gestion des abonnements SOC/EDR/XDR	Exécution du contrat	Commandes, Stripe Cashier, webhooks
Support client et contact	Intérêt légitime / mesures précontractuelles	Formulaire contact, chatbot, réponses admin
Sécurité et prévention de la fraude	Intérêt légitime (art. 6.1.f)	Journal d'audit, rate limiting, OTP admin
Obligations comptables et légales	Obligation légale (art. 6.1.c)	Conservation anonymisée de certaines traces de commande

4. Durées de conservation

Donnée	Durée	Mécanisme technique
--------	-------	---------------------

Compte utilisateur actif	Durée de la relation contractuelle	Tant que le compte existe
Token de confirmation e-mail	24 heures (configurable)	Purge automatique quotidienne (<code>users:purge-expired-email-verification-tokens</code>)
Token de réinitialisation mot de passe	Jusqu'à expiration (60 min) puis purge	<code>users:purge-expired-reset-tokens</code>
Journal d'audit (<code>logs</code>)	365 jours par défaut (min. 30 jours)	<code>AuditLogger::purgeExpired()</code> — variable <code>AUDIT_LOG_RETENTION_DAYS</code>
Messages chatbot	Jusqu'à suppression du compte	Suppression à l'effacement du compte
Données de commande	Obligation comptable (10 ans en droit français) — traces anonymisées après effacement	Conservation sans identifiant utilisateur
Codes promo expirés	Désactivation automatique à la date d'expiration	<code>promo-codes:deactivate-expired</code>

5. Vos droits

Conformément au Règlement (UE) 2016/679 (RGPD) et à la loi Informatique et Libertés, vous disposez des droits suivants :

Droit	Comment l'exercer sur CYNA
Accès (art. 15)	Consulter votre profil : <code>GET /api/profile</code> (espace « Mon compte » sur le site ou l'app)
Rectification (art. 16)	Modifier prénom, nom, e-mail, mot de passe : <code>PUT /api/profile</code>
Effacement (art. 17)	Supprimer votre compte : <code>DELETE /api/profile</code> — mot de passe + saisie de « SUPPRIMER »
Limitation / opposition	Contactez rgpd@cyna-it.fr — blocage possible par l'administrateur (<code>bloquer</code>)
Portabilité (art. 20)	Sur demande à rgpd@cyna-it.fr — export des données de profil et commandes
Réclamation	CNIL — www.cnil.fr

5.1 Suppression de compte — détail technique

Lorsque vous demandez la suppression de votre compte (`DELETE /api/profile`), la plateforme exécute automatiquement les opérations suivantes :

- Annulation immédiate des abonnements actifs (Stripe)
- Suppression du client Stripe et des moyens de paiement associés
- Suppression de vos adresses et de l'historique chatbot
- Anonymisation de vos messages de contact (e-mail remplacé par `deleted+{id}@anonymized.local`)
- Anonymisation du journal d'audit (identifiant et IP effacés)
- Conservation anonymisée des seules traces nécessaires : création de commande, checkout, confirmation de suppression
- Révocation de tous vos tokens de connexion
- Suppression définitive de votre compte utilisateur

Les comptes administrateur ne peuvent pas être supprimés depuis l'espace client.

6. Minimisation et journalisation

CYNA applique le principe de minimisation des données (art. 5.1.c RGPD) :

- **Parcours web** : seules 12 pages liées au commerce et au compte sont journalisées (panier, checkout, mon compte, etc.) — pas de suivi du catalogue public ni des pages légales.
- **Page-views** : aucune adresse IP n'est enregistrée pour les visites de pages.
- **Utilisateurs standards** : seules les requêtes de modification (POST, PUT, PATCH, DELETE) sont journalisées — pas les consultations (GET) du catalogue.
- **Adresses IP** : lorsqu'elles sont enregistrées (actions API), le dernier octet IPv4 est mis à zéro ; les segments finaux IPv6 sont tronqués.
- **Invités non connectés** : aucune action n'est journalisée dans le registre d'audit.

7. Sécurité des données

- **Chiffrement des mots de passe** : bcrypt avec 12 rounds en production.
- **Transport** : HTTPS obligatoire (Render, Supabase TLS `require`).
- **Paiements** : traités par Stripe — CYNA ne stocke jamais les numéros de carte complets.
- **Authentification API** : tokens Bearer Sanctum révocables à la déconnexion ou au blocage du compte.

- **Accès aux données sensibles** : commandes et paiements réservés aux utilisateurs dont l'e-mail est confirmé.
- **Administration** : double facteur par code OTP envoyé par e-mail (15 min, 5 tentatives max).
- **Limitation des tentatives** : rate limiting sur l'authentification et le formulaire de contact.

8. Sous-traitants et transferts

Prestataire	Rôle	Localisation	Garanties
Supabase	Hébergement base de données PostgreSQL	Union européenne (EU-West-1)	Clauses contractuelles types, TLS
Render.com	Hébergement API et front web	Frankfurt (UE)	HTTPS, isolation services
Stripe	Paielements et abonnements	UE / garanties Stripe DPA	PCI-DSS Level 1
Cloudinary	Hébergement images (backoffice admin)	À vérifier selon contrat	Accès restreint admin
Gmail (Google)	Envoi d'e-mails transactionnels	USA — garanties Google Cloud DPA	SMTP TLS, mot de passe d'application

9. Cookies et traceurs

Le site CYNA utilise des cookies techniques nécessaires au fonctionnement (session PHP côté front) et des tokens d'authentification côté application mobile. Le journal de parcours commerce (page-view) ne collecte pas d'adresse IP et est limité aux pages listées en section 6. Aucun cookie publicitaire tiers n'est implémenté dans l'API CYNA.

10. Mineurs

La plateforme CYNA s'adresse aux professionnels (PME). Elle n'est pas destinée aux personnes de moins de 16 ans. Nous ne collectons pas sciemment de données concernant des mineurs.

11. Modifications de la politique

Cette politique peut être mise à jour pour refléter l'évolution du service ou de la réglementation. La date de dernière mise à jour figure en en-tête. En cas de modification substantielle, les utilisateurs en seront informés par e-mail ou via une notification sur le site.

12. Références techniques (implémentation)

Les mesures décrites dans ce document correspondent aux composants logiciels suivants :

- `app/Services/AccountDeletionService.php` — effacement et anonymisation
- `app/Services/AuditLogger.php` — journalisation, masquage IP, purge
- `config/audit.php` — durées, pages autorisées, actions conservées
- `app/Http/Controllers/Api/ProfileController.php` — accès, rectification, suppression
- `app/Http/Middleware/EnsureEmailIsVerified.php` — consentement implicite e-mail
- `routes/console.php` — tâches planifiées de purge